



Utkarsh Arora &lt;utkarsh20143@iiitd.ac.in&gt;

## Report issue - Group 3

2 messages

**Google Forms** <forms-receipts-noreply@google.com>  
To: utkarsh20143@iiitd.ac.in

Sun, Dec 4, 2022 at 3:11 AM

Thanks for filling out [Report issue - Group 3](#)

Here's what was received.

## Report issue - Group 3

Please fill out this form to report an issue/vulnerability in the group 3.

Your email ([utkarsh20143@iiitd.ac.in](mailto:utkarsh20143@iiitd.ac.in)) was recorded when you submitted this form.

### Vulnerability type

\*

Select the type of vulnerability, or specify a custom one.

☐ XSS

☐ CSRF

☒ Feature bug

☐ Other: .....

### Steps to reproduce

\*

Describe the steps to reproduce the vulnerability.

Log in to the website

Go to the Buy Medicines tab

There is a method to search for medicines, and a method to pay; but there is no way to buy medicines

### Proof of concept

\*

Provide a proof of concept for the vulnerability.

There is no way to actually order medicines on the website. There is a query to search for medicines, but there is no way to put them into the cart. And therefore there is no way to actually order them, which means there is no way to buy them. Thus the payment feature exists in isolation, with no tangible product to actually use the payment feature for.

### Impact

\*

Describe the impact of the vulnerability. How bad is it?

Medium; ordering medicines is an important feature of the website. In a real world scenario, ordering medicines from pharmacies would be one of the main reason why people would use such a website.

### Screenshots/attachments

Provide screenshots or other attachments to help explain the vulnerability.

#### Submitted files



fcs\_3\_2\_1 - Utkarsh Arora.png



fcs\_3\_2\_2 - Utkarsh Arora.png

Create your own Google Form

Report Abuse

Google Forms <forms-receipts-noreply@google.com>  
To: utkarsh20143@iiitd.ac.in

Sun, Dec 4, 2022 at 12:56 PM

Thanks for filling out [Report issue - Group 3](#)

Here's what was received.

## Report issue - Group 3

Please fill out this form to report an issue/vulnerability in the group 3.

Your email ([utkarsh20143@iiitd.ac.in](mailto:utkarsh20143@iiitd.ac.in)) was recorded when you submitted this form.

### Vulnerability type

\*

Select the type of vulnerability, or specify a custom one.

☐ XSS

☐ CSRF

☐ Feature bug

☒ Other: DOS

### Steps to reproduce

\*

Describe the steps to reproduce the vulnerability.

Sign up on the website

Now try to log in

An OTP will be sent to the email registered with the account

If we spam this post request, the OTP will be sent again and again

The website has a rate limit, but this rate limit is 20 requests per minute.

The email used to send out OTP requests is a gmail account. These accounts have a sending limit of 2000 emails per day.

Hence, if the login request is spammed within the rate limit, the email sending limit will be reached within 2 hours, and the email won't be able to send out more emails for the next 22 hours, and therefore the login functionality will be jammed for the next 22 hours.

### Proof of concept

\*

Provide a proof of concept for the vulnerability.

I registered myself on the website, and then tried to login to the website. I intercepted the POST request on BurpSuite. I tried spamming it, but it notified me of the rate limit, which is 20 requests per minute. So I wrote a script in python, that sends the request, then sleeps a few seconds, then sends the next request, thus bypassing the rate limit.

In about two hours, enough requests were sent that the OTP sending email's sending limits were reached. Hence, no more emails can be sent for the rest of the day, and therefore the login functionality is blocked.

When I try logging in again, no OTP is sent to my email, which means that the OTP functionality is blocked.

---

## Impact

\*

Describe the impact of the vulnerability. How bad is it?

High severity; for 22 hours the login functionality of the website is jammed, and thus no user can log in to the website for those 22 hours, which means that the site is essentially totally unavailable.

This attack can be run again the next day, which means that excluding the two hours needed to run the attack, the site can be always unavailable.

---

## Screenshots/attachments

Provide screenshots or other attachments to help explain the vulnerability.

### Submitted files



fcs\_3\_3\_1 - Utkarsh Arora.png



fcs\_3\_3\_2 - Utkarsh Arora.png



fcs\_3\_3\_3 - Utkarsh Arora.png



fcs\_3\_3\_4 - Utkarsh Arora.png



fcs\_3\_3\_6 - Utkarsh Arora.png

[Quoted text hidden]